

SF01 – Seguridad Fisica de la Infraestructura del PSC

ID Documento: GOYA-SF01-001 **Version:** 1.0 **Fecha:** 2026-09-01 **Estado:** Borrador **Autor:** Oficial de Seguridad **Aprobado por:** Pendiente – Gerencia General **Clasificacion:** Confidencial **Proximo revision:** 2027-03-01

Version	Fecha	Autor	Cambios
1.0	2026-09-01	Oficial de Seguridad	Documento inicial

1. Objetivo y Alcance

1.1 Objetivo

Definir los controles de seguridad fisica aplicables a la infraestructura de Goya Ledger SpA en su operacion como Prestador de Servicios de Certificacion (PSC) bajo la Ley 19.799 y DS 181/2002. Este documento cumple con el sub-proceso SF01 de la Guia de Acreditacion EA-103 v2.1 (seccion 4.16), alineado con ISO/IEC 27002:2022 seccion 7 (controles 7.1 a 7.14) y ETSI TS 102 042 seccion 7.4.4.

1.2 Alcance

Los controles aplican a toda la infraestructura que soporta los servicios de confianza del PSC:

- **Autoridad Certificadora (CA):** CA raiz offline y CA intermedia operativa.
- **Autoridad de Sellado de Tiempo (TSA):** Sellos RFC 3161 con precision NTP.
- **Respondedor OCSP:** Consultas de estado de certificados en tiempo real.
- **Autoridad de Registro (RA):** Verificacion de identidad presencial y remota.
- **Infraestructura de computo:** Nodos BFT (Rust/Actix-Web 4), almacenamiento RocksDB, red P2P con TLS 1.3.
- **Componentes de soporte:** Estaciones de administracion, equipos de ceremonia de llaves, medios de respaldo.

1.3 Modelo de despliegue

Goya Ledger opera con un modelo híbrido: infraestructura operativa en nube pública (Fly.io, región IAD) complementada con una bóveda offline para material criptográfico raíz. Este modelo se ampara en el principio de neutralidad tecnológica establecido en EA-103 v2.1 sección 2.3.5, que permite al PSC elegir libremente la tecnología de soporte siempre que se cumplan los requisitos de seguridad del marco normativo.

La sección 2.3.5 de EA-103 establece que la Entidad Acreditadora no prescribe una infraestructura física particular; lo que se evalúa es la capacidad demostrable de cumplir los controles de seguridad, independientemente de si la infraestructura es propia, arrendada o provista por un tercero en modalidad de nube.

2. Marco Normativo

Norma	Sección	Aplicación
ISO/IEC 27002:2022	7.1 – 7.14	Controles de seguridad física completos
ETSI TS 102 042	7.4.4	Seguridad física y ambiental para CA cualificadas
ETSI EN 319 401	7.6	Requisitos físicos para prestadores de servicios de confianza
Ley 19.799	Art. 12-17	Obligaciones del PSC
DS 181/2002	Art. 14-16	Requisitos de infraestructura del PSC
EA-103 v2.1	4.16	Sub-proceso de seguridad física
EA-103 v2.1	2.3.5	Neutralidad tecnológica
FIPS 140-3	Level 2/3	Seguridad física de módulos criptográficos
ISO/IEC 27001:2022	A.7	Controles físicos del Anexo A

3. Modelo de Infraestructura Física

3.1 Arquitectura de tres niveles

La infraestructura se organiza en tres niveles (tiers) con requisitos de seguridad física decrecientes:

Nivel	Descripción	Ubicación	Componentes
		Instalación física controlada (caja de	HSM, llaves raíz, equipos de ceremonia,

Nivel	Descripcion	Ubicacion	Componentes
Nivel 1 – Alta seguridad	Boveda offline para CA raiz y material criptografico	seguridad bancaria o boveda dedicada)	shares de recuperacion
Nivel 2 – Operativo	Infraestructura de produccion para CA intermedia, TSA, OCSP, RA	Fly.io datacenter IAD (Ashburn, Virginia)	Nodos BFT, almacenamiento RocksDB, red P2P, API publica
Nivel 3 – Soporte	Estaciones de administracion, desarrollo, monitoreo	Oficinas del equipo operativo	Estaciones de trabajo, consolas de administracion, entornos de staging

3.2 Justificacion del modelo nube

El despliegue operativo en Fly.io se justifica por:

1. **Neutralidad tecnologica (EA-103 seccion 2.3.5):** El marco regulatorio no exige infraestructura propia. La obligacion es demostrar cumplimiento de controles, no propiedad del hardware.
2. **Segregacion del material raiz:** Las llaves de la CA raiz nunca residen en la nube. Se mantienen offline en Nivel 1 con acceso ceremonial.
3. **Controles compensatorios:** Donde el proveedor cloud no ofrece un control fisico directamente verificable, se implementan controles logicos equivalentes documentados en la seccion 5 de este documento.
4. **Certificaciones del proveedor:** Fly.io opera en datacenters SOC 2 Type II (Equinix IAD) con controles fisicos auditados por terceros independientes.

4. Controles ISO/IEC 27002:2022 Seccion 7

4.1 Mapeo de controles

La siguiente tabla mapea cada control de ISO/IEC 27002:2022 seccion 7 a su implementacion en el modelo hibrido de Goya Ledger.

Leyenda de responsabilidad: - **PP:** Proveedor de plataforma (Fly.io / datacenter subyacente) - **GL:** Goya Ledger (propio) - **COM:** Compartida

#	Control	Nombre	Aplica	Responsable	Implementacion	Evidencia
7.1	Perimetros de seguridad fisica	Si	PP (Nivel 2), GL (Nivel 1)	Nivel 2: datacenter Equinix con perimetro fisico, acceso controlado por badge + biometrico. Nivel 1: boveda bancaria o sala	Certificacion SOC 2 del datacenter; contrato de boveda; registro fotografico	

#	Control	Nombre	Aplica	Responsable	Implementacion	Evidencia
7.2	Controles de entrada fisica	Si	PP (Nivel 2), GL (Nivel 1, 3)	dedicada con acceso restringido. Nivel 2: control de acceso del datacenter (badge, biometrico, registro). Nivel 1: acceso dual (dos custodios), registro en bitacora de ceremonia. Nivel 3: badge + llave en oficinas.	Logs de acceso del datacenter; bitacora de ceremonias; registro de visitantes	
7.3	Asegurar oficinas, salas e instalaciones	Si	PP (Nivel 2), GL (Nivel 1, 3)	Nivel 2: datacenter con jaulas/racks cerrados. Nivel 1: boveda sin ventanas, muros reforzados. Nivel 3: puertas con cerradura, politica de escritorio limpio.	Planos de instalaciones; fotografias; inventario de cerraduras	
7.4	Monitoreo de seguridad fisica	Si	PP (Nivel 2), GL (Nivel 1)	Nivel 2: CCTV 24/7 del datacenter con retencion minima 90 dias. Nivel 1: CCTV en boveda con retencion 1 ano. Nivel 3: monitoreo basico de oficina.	Politica de retencion de video; acuerdo con proveedor; capturas de sistema	
7.5	Proteccion contra amenazas fisicas y ambientales	Si	PP (Nivel 2), GL (Nivel 1)	Nivel 2: supresion de incendios (gas inerte), deteccion de agua, HVAC redundante, estructura antisismica. Nivel 1: boveda ignifuga (rating minimo 2 horas),	Certificados de supresion; especificaciones de boveda; informes de mantenimiento	

#	Control	Nombre	Aplica	Responsable	Implementacion	Evidencia
7.6	Trabajo en areas seguras	Si	COM	deteccion de inundacion. Nivel 2: politica del datacenter (sin dispositivos fotograficos, supervision de visitantes). Nivel 1: regla de dos personas, prohibicion de dispositivos electronicos personales, testigos en ceremonias.	Politica de areas restringidas; actas de ceremonia	
7.7	Escritorio limpio y pantalla limpia	Si	GL	Nivel 3: politica de escritorio limpio. Bloqueo automatico de pantalla a 5 minutos. No se almacena material criptografico en estaciones de trabajo.	Politica interna; configuracion de screensaver; auditorias periodicas	
7.8	Ubicacion y proteccion de equipos	Si	PP (Nivel 2), GL (Nivel 1)	Nivel 2: racks en datacenter con control ambiental (18-27C, 40-60% HR). Nivel 1: HSM en boveda con condiciones controladas.	Reportes ambientales del datacenter; registro de condiciones de boveda	
7.9	Seguridad de activos fuera de las instalaciones	Si	GL	Medios de respaldo cifrados (AES-256) durante transporte. Shares de recuperacion distribuidos geograficamente. Equipos de ceremonia transportados en contenedores de seguridad con	Procedimiento de transporte; registro de sellos; cifrado verificable	

#	Control	Nombre	Aplica	Responsable	Implementacion	Evidencia
7.10	Medios de almacenamiento	Si	GL	sellos anti-tamper. Cifrado en reposo para todos los medios. Destruccion segura (NIST SP 800-88) al fin de vida. Inventario mensual de medios con material criptografico.	Inventario de medios; certificados de destruccion; politica de cifrado	
7.11	Servicios de soporte (utilidades)	Si	PP (Nivel 2), GL (Nivel 1)	Nivel 2: datacenter con UPS + generador diesel, alimentacion electrica redundante, enlaces de red redundantes. Nivel 1: boveda independiente de servicios continuos (acceso puntual para ceremonias).	SLA del datacenter; especificaciones de redundancia electrica	
7.12	Seguridad del cableado	Si	PP (Nivel 2)	Nivel 2: cableado estructurado en datacenter (piso elevado o bandejas aereas), puertos no utilizados deshabilitados. Nivel 1: no aplica (equipos air-gapped).	Diagrama de cableado del datacenter; configuracion de puertos	
7.13	Mantenimiento de equipos	Si	COM	Nivel 2: mantenimiento por el proveedor cloud segun SLA. Nivel 1: mantenimiento del HSM por personal autorizado con	Registros de mantenimiento; SLA; bitacora de intervencion HSM	

#	Control	Nombre	Aplica	Responsable	Implementacion	Evidencia
7.14	Eliminacion o reutilizacion segura de equipos	Si	COM	supervision dual. Nivel 3: mantenimiento estandar de equipos de oficina. Nivel 2: responsabilidad del proveedor cloud con certificacion de sanitizacion. Nivel 1: destruccion fisica del HSM supervisada con acta notarial. Nivel 3: borrado seguro (NIST SP 800-88 Rev.1) antes de reutilizacion.	Certificados de destruccion; actas notariales; registros de borrado	

4.2 Controles no aplicables directamente

Todos los controles 7.1 a 7.14 son aplicables. No existen exclusiones. Los controles que recaen en el proveedor cloud se verifican mediante:

1. Certificacion SOC 2 Type II vigente del datacenter subyacente.
2. Clausulas contractuales que exigen notificacion de incidentes fisicos.
3. Auditoria anual de evidencia documental provista por el proveedor.

5. Seguridad del Proveedor Cloud

5.1 Fly.io como proveedor de infraestructura

Aspecto	Detalle
Proveedor	Fly.io, Inc.
Region de despliegue	IAD (Ashburn, Virginia, USA)
Datacenter subyacente	Equinix IAD
Certificacion	SOC 2 Type II (Equinix)
Modelo de responsabilidad	Infraestructura como Servicio (IaaS) con contenedores Firecracker
SLA de disponibilidad	99.99% (infraestructura de computo)
Redundancia de red	Multiples proveedores de transito, conectividad redundante

Aspecto	Detalle
Redundancia electrica	UPS + generadores diesel con autonomia minima 48 horas

5.2 Controles fisicos delegados

Los siguientes controles fisicos son responsabilidad directa del proveedor cloud y se verifican a traves de sus certificaciones:

1. **Perimetro fisico del datacenter:** Cercado, barreras vehiculares, puntos de acceso controlados.
2. **Control de acceso al datacenter:** Biometrico + badge + PIN. Registro electronico de accesos.
3. **CCTV:** Cobertura 24/7 de todas las areas, retencion minima 90 dias.
4. **Deteccion y supresion de incendios:** Sistemas de gas inerte (FM-200 o equivalente), detectores de humo en todos los niveles.
5. **Control ambiental:** HVAC redundante, temperatura 18-27C, humedad relativa 40-60%.
6. **Proteccion contra inundaciones:** Sensores de agua, datacenter en piso elevado.
7. **Proteccion sismica:** Estructura disenada para la zona sismica de Virginia (bajo riesgo).
8. **Seguridad del cableado:** Cableado estructurado, gabinetes cerrados, puertos deshabilitados.

5.3 Verificacion periodica

Actividad	Frecuencia	Responsable
Solicitar reporte SOC 2 actualizado	Anual	Oficial de Seguridad
Revisar clausulas de seguridad fisica en contrato	Anual (o en renovacion)	Oficial de Seguridad
Verificar notificaciones de incidentes fisicos	Continua	Equipo de operaciones
Evaluar alternativas de proveedor	Bianual	Gerencia General
Auditar evidencia de controles delegados	Anual	Auditor externo

5.4 Riesgo residual del modelo cloud

El modelo cloud introduce un riesgo inherente: la imposibilidad de verificar directamente los controles fisicos del datacenter. Este riesgo se mitiga mediante:

1. **Cadena de confianza auditable:** SOC 2 Type II del datacenter subyacente emitido por auditor AICPA.
2. **Clausulas contractuales:** Obligacion de notificacion de incidentes fisicos dentro de 24 horas.

3. **Plan de contingencia:** Procedimiento de migración a proveedor alternativo documentado en PS03 (sección de continuidad de negocio).
 4. **Segregación de activos críticos:** Material criptográfico raíz nunca reside en la nube (ver sección 6).
-

6. Almacenamiento Offline de Llaves Raíz

6.1 Requisitos de la bóveda

La CA raíz opera exclusivamente offline. El material criptográfico raíz se almacena en una bóveda física que cumple los siguientes requisitos:

Requisito	Especificación
Tipo de instalación	Caja de seguridad bancaria grado TL-30 o bóveda dedicada
Protección contra incendio	Rating mínimo UL 2 horas a 1010C
Protección contra inundación	Sensores de agua, ubicación sobre nivel de riesgo de inundación
Control de acceso	Llave física + combinación numérica, acceso dual obligatorio
Registro	Bitácora firmada por ambos custodios en cada acceso
CCTV	Cámara sobre la bóveda con retención mínima 1 año
Contenido	HSM con llaves raíz, shares de recuperación (M-of-N), equipos de ceremonia
Conectividad	Ninguna (air-gapped)
Dispositivos electrónicos	Prohibidos dentro de la bóveda excepto equipos de ceremonia dedicados

6.2 Ceremonia de acceso a llaves raíz

Cada acceso a la bóveda de llaves raíz sigue un protocolo ceremonial:

1. **Convocatoria:** El Oficial de Seguridad emite convocatoria escrita con al menos 48 horas de anticipación, indicando propósito y participantes.
2. **Quorum:** Mínimo dos custodios autorizados presentes. Ningún custodio puede acceder solo.
3. **Verificación de identidad:** Identificación con documento oficial vigente de cada participante.
4. **Registro de ingreso:** Ambos custodios firman la bitácora con fecha, hora y propósito.
5. **Prohibición de dispositivos:** Teléfonos, laptops y dispositivos de almacenamiento externo se depositan en casillero exterior.
6. **Ejecución:** Solo se realizan las operaciones declaradas en la convocatoria.
7. **Verificación de integridad:** Al concluir, se verifican sellos anti-tamper del HSM y se registra su estado.

8. **Registro de salida:** Ambos custodios firman la bitacora con hora de salida y resultado de la verificacion de integridad.
9. **Acta de ceremonia:** Se genera un acta que incluye hashes de cualquier material criptografico generado o utilizado.

6.3 Custodios autorizados

Rol	Cantidad minima	Designacion
Custodio primario	2	Designados por Gerencia General
Custodio suplente	1	Para contingencia ante indisponibilidad
Testigo de ceremonia	1	Requerido en operaciones de generacion de llaves

La lista de custodios se revisa semestralmente. La revocacion de acceso se ejecuta dentro de 24 horas ante cambio de rol o desvinculacion.

6.4 Shares de recuperacion

Los shares de recuperacion del VAULT_RECOVERY_SECRET se distribuyen bajo esquema M-of-N:

- **N total:** Minimo 5 shares.
- **M umbral:** Minimo 3 para reconstruccion.
- **Distribucion geografica:** Cada share en ubicacion fisica distinta.
- **Custodia individual:** Un share por custodio, sin duplicacion.
- **Cifrado individual:** Cada share cifrado con la llave personal del custodio.

7. Proteccion contra Desastres

7.1 Incendio

Nivel	Control	Implementacion
Nivel 1	Boveda ignifuga	Rating UL 2 horas; extintores portatiles clase C en area adyacente
Nivel 2	Supresion automatica	Sistema de gas inerte (FM-200/Novec 1230) del datacenter; sin agua en areas de servidores
Nivel 3	Deteccion y extincion estandar	Detectores de humo, extintores clase ABC, rociadores en areas de oficina

7.2 Inundacion

Nivel	Control	Implementacion
Nivel 1	Seleccion de ubicacion + sensores	Boveda en piso elevado o ubicacion geografica sin riesgo historico de inundacion; sensores de agua
Nivel 2	Diseno del datacenter	Piso elevado (30 cm minimo), sensores de filtracion, bombas de drenaje
Nivel 3	Proteccion basica	Equipos sobre muebles, sin instalacion a nivel de suelo

7.3 Sismo

Nivel	Control	Implementacion
Nivel 1	Boveda con especificacion sismica	Instalacion en estructura que cumpla normativa sismica local
Nivel 2	Estructura antisismica del datacenter	Equinix IAD cumple codigos de construccion de Virginia (zona sismica moderada-baja)
Nivel 3	Anclaje de equipos	Racks y monitores asegurados a escritorios/paredes

7.4 Falla electrica

Nivel	Control	Implementacion
Nivel 1	Independiente de suministro continuo	Boveda no requiere electricidad permanente; equipos de ceremonia con baterias propias
Nivel 2	Redundancia completa	UPS (30 min autonomia minima) + generador diesel (48+ horas); alimentacion desde dos subestaciones independientes
Nivel 3	UPS basico	UPS para estaciones criticas de administracion (15 min para shutdown ordenado)

7.5 Falla de telecomunicaciones

Nivel	Control	Implementacion
Nivel 1	No aplica	Boveda air-gapped, sin conectividad
Nivel 2	Redundancia de red	Multiples proveedores de transito en datacenter; conmutacion automatica; monitoreo de latencia y disponibilidad
Nivel 3	Enlace de respaldo	

Nivel	Control	Implementacion
		Conexion secundaria (4G/5G) para administracion de emergencia

7.6 Falla estructural

Nivel	Control	Implementacion
Nivel 1	Inspeccion periodica	Verificacion anual de integridad estructural de la boveda
Nivel 2	Responsabilidad del datacenter	Programa de mantenimiento estructural del edificio (Equinix)
Nivel 3	Inspeccion visual	Verificacion semestral de oficinas y areas de trabajo

8. Controles de Acceso Fisico

8.1 Politica de visitantes

1. Todo visitante se identifica con documento oficial vigente en recepcion.
2. Se emite credencial de visitante visualmente diferenciada de las credenciales de empleado.
3. Escolta obligatoria en todo momento dentro de areas de Nivel 1 y Nivel 2.
4. Prohibicion de dispositivos electronicos personales en areas de Nivel 1.
5. Registro en bitacora de visitantes con: nombre, organizacion, documento, hora de ingreso, hora de salida, area visitada, nombre del acompanante.
6. La bitacora de visitantes se retiene por 7 anos conforme a la politica de retencion de auditoria.

8.2 Monitoreo y alarmas

Sistema	Cobertura	Retencion / Respuesta
CCTV	Nivel 1 y Nivel 2 (todas las areas)	Nivel 1: 1 ano. Nivel 2: 90 dias (datacenter).
Sensores de movimiento	Nivel 1 (fuera de horario de ceremonia)	Alarma al Oficial de Seguridad
Sensores de puerta	Todos los puntos de acceso controlados	Registro en tiempo real
Sensores ambientales	Temperatura, humedad, agua, humo	Alerta automatica + failover HVAC
Deteccion de intrusion		Alarma + incidente P2 (ver PS07)

Sistema	Cobertura	Retencion / Respuesta
	Perimetro (datacenter), chasis de servidores	

8.3 Revocacion de acceso

- Cambio de rol: revocacion dentro de 24 horas.
- Desvinculacion: revocacion inmediata al momento de notificacion.
- Revision trimestral de listas de acceso por el Oficial de Seguridad.
- Los accesos revocados se registran en la bitacora con motivo y fecha.

9. Mantenimiento de Equipos

9.1 Equipos en Nivel 1 (HSM y equipos de ceremonia)

Actividad	Frecuencia	Responsable	Protocolo
Verificacion de sellos anti-tamper	Cada acceso a boveda	Custodios (dual)	Inspeccion visual, comparacion con registro fotografico previo
Actualizacion de firmware HSM	Segun boletines del fabricante	Personal autorizado + custodio	Ceremonia con testigo, respaldo previo de configuracion
Prueba de zeroizacion	Anual	Personal autorizado	Verificacion de que el mecanismo de zeroizacion del HSM responde correctamente
Reemplazo de bateria del HSM	Segun especificacion del fabricante	Personal autorizado + custodio	Ceremonia con verificacion de integridad pre y post

9.2 Equipos en Nivel 2 (infraestructura cloud)

El mantenimiento de hardware en Nivel 2 es responsabilidad del proveedor cloud conforme a su SLA. Goya Ledger:

1. Monitorea metricas de salud de los nodos via la API de Fly.io.
2. Verifica que los reinicios o migraciones de maquinas virtuales no afecten la integridad de datos (RocksDB con WAL).

3. Mantiene procedimiento de redespliegue automatizado ante falla de nodo.

9.3 Equipos en Nivel 3 (estaciones de trabajo)

Actividad	Frecuencia	Responsable
Actualizacion de sistema operativo	Mensual o ante parche critico	Equipo de operaciones
Verificacion de cifrado de disco	Trimestral	Oficial de Seguridad
Verificacion de bloqueo automatico de pantalla	Trimestral	Oficial de Seguridad
Inventario de equipos	Semestral	Equipo de operaciones

10. Eliminacion y Reutilizacion Segura

10.1 Material criptografico (Nivel 1)

- **HSM al fin de vida:** Zeroizacion del material criptografico seguida de destruccion fisica supervisada. Acta notarial con numero de serie, fecha y testigos.
- **Medios con shares de recuperacion:** Destruccion fisica (trituracion) con certificado de destruccion.
- **Equipos de ceremonia:** Borrado seguro (NIST SP 800-88 Rev.1, metodo Clear o Purge) antes de reutilizacion o destruccion.

10.2 Infraestructura cloud (Nivel 2)

- La sanitizacion de hardware es responsabilidad del proveedor cloud.
- Goya Ledger verifica que el contrato incluya clausulas de destruccion segura de datos al termino del servicio.
- Los datos en disco estan cifrados en reposo; la eliminacion de llaves de cifrado constituye sanitizacion logica efectiva.

10.3 Estaciones de trabajo (Nivel 3)

- Borrado seguro conforme a NIST SP 800-88 Rev.1 antes de reasignacion o descarte.
 - Registro de borrado con identificacion del equipo, metodo utilizado y responsable.
-

11. Coherencia con PS01

Los riesgos identificados en PS01 (Plan de Gestion de Riesgos) con componente de seguridad fisica se mapean a los controles de este documento:

Riesgo PS01	Categoria	Control SF01	Seccion
R-PHYS-01: Acceso no autorizado a instalaciones	Acceso fisico	Controles 7.1, 7.2, 7.6; ceremonia de acceso	4.1, 6.2, 8
R-PHYS-02: Perdida de material criptografico	Proteccion de activos	Boveda offline, shares M-of-N	6
R-PHYS-03: Desastre natural (incendio, inundacion, sismo)	Continuidad	Controles 7.5; proteccion por nivel	7
R-PHYS-04: Falla de suministro electrico	Disponibilidad	Control 7.11; redundancia del datacenter	4.1 (7.11), 7.4
R-PHYS-05: Falla de telecomunicaciones	Disponibilidad	Redundancia de red del datacenter	7.5
R-PHYS-06: Compromiso del proveedor cloud	Tercerizacion	Verificacion de certificaciones, plan de migracion	5
R-PHYS-07: Tamper de equipos	Integridad	Sellos anti-tamper, verificacion en cada acceso	9.1
R-ENV-01: Condiciones ambientales fuera de rango	Ambiental	Control 7.8; monitoreo ambiental	4.1 (7.8), 8.2

Los controles de este documento se evaluan conforme a la metodologia de riesgo residual de PS01 (seccion 2). Los riesgos con tratamiento “transferir” (proveedor cloud) mantienen control compensatorio via clausulas contractuales y verificacion de certificaciones.

12. Revision y Mantencion

12.1 Ciclo de revision

Actividad	Frecuencia	Responsable
Revision ordinaria del documento	Semestral	Oficial de Seguridad

Actividad	Frecuencia	Responsable
Revision extraordinaria	Ante incidente fisico, cambio de proveedor, o cambio normativo	Oficial de Seguridad + Gerencia General
Auditoria interna de controles fisicos	Anual	Auditor interno
Auditoria externa	Segun ciclo de acreditacion EA-103	Auditor externo designado por la Entidad Acreditadora
Ejercicio de ceremonia de llaves	Semestral	Oficial de Seguridad + Custodios
Verificacion de SLA del proveedor cloud	Trimestral	Equipo de operaciones

12.2 Criterios de revision extraordinaria

Se activa una revision extraordinaria ante cualquiera de los siguientes eventos:

1. Incidente de seguridad fisica clasificado P1 o P2 (ver PS07).
2. Cambio de proveedor cloud o de region de despliegue.
3. Cambio en la normativa aplicable (EA-103, ISO 27002, ETSI TS 102 042).
4. Resultado adverso de auditoria interna o externa.
5. Cambio en la ubicacion de la boveda de Nivel 1.
6. Incorporacion de nueva infraestructura fisica.

12.3 Indicadores de efectividad

Indicador	Meta	Medicion
Incidentes de acceso fisico no autorizado	0 por semestre	Bitacoras de acceso + alarmas
Cumplimiento de ceremonias con protocolo completo	100%	Actas de ceremonia
Disponibilidad del proveedor cloud	>= 99.99%	Reportes de uptime de Fly.io
Revision de listas de acceso en plazo	100% trimestral	Registro de revisiones
Reporte SOC 2 vigente del proveedor	Siempre vigente	Fecha de emision del reporte

13. Referencias

Referencia	Descripcion
ISO/IEC 27002:2022	Controles de seguridad de la informacion, seccion 7 (Controles fisicos)
ISO/IEC 27001:2022	

Referencia	Descripcion
	Sistemas de gestion de seguridad de la informacion, Anexo A.7
ETSI TS 102 042 v2.4.1	Requisitos de politica para CA que emiten certificados cualificados, seccion 7.4.4
ETSI EN 319 401 v2.3.1	Requisitos generales para prestadores de servicios de confianza
Ley 19.799 (Chile)	Documentos electronicos, firma electronica y servicios de certificacion
DS 181/2002 (Chile)	Reglamento de la Ley 19.799
EA-103 v2.1	Guia de Acreditacion de PSC, Subsecretaria de Economia
FIPS 140-3	Requisitos de seguridad para modulos criptograficos
NIST SP 800-88 Rev.1	Guias para la sanitizacion de medios
PS01 – GOYA-PS01-001	Plan de Gestion de Riesgos y Amenazas
PS03 – GOYA-PS03-001	Plan de Continuidad de Negocio
PS06 – GOYA-PS06-001	Plan de Gestion de Llaves
PS07 – GOYA-PS07-001	Plan de Gestion de Incidentes
GOYA-PHYS-001	Requisitos de Seguridad Fisica (documento tecnico base)